正規アカウントが悪用されたとき、どこで操作を止められるか

印刷用PDF版 v1.0.0 | 2026-11-11 JST

Masao Gate Labs · 事案分析・適用例 001 2026年11月10日公開。MGLの白書草案をもとにした公開編集版です。

報道と公表資料から分かること

2025年12月、Bloombergは、Amazonのセキュリティ担当者が委託先からの接続を調べ、キー入力に関するデータを手掛かりに、北朝鮮のIT労働者によるなりすましを発見したと報じました。米司法省も別の発表で、虚偽または盗用した身元を使ったリモートIT就業と、企業支給端末への遠隔アクセスを仲介する手口を説明しています。司法省の発表は同種の事案の背景資料です。Bloomberg · 米司法省

MGLが検討する制御点

身元確認や不審な接続の調査に加え、ログイン後の個別操作にも制御点を置きます。保守担当者やAIが利用できるツールに書き込み機能があっても、実行の直前に、対象と操作が委任範囲に収まるかを独立した実行制御点で確認します。許可した更新が行われたか、拒否した要求の対象がどうなったかは、実行側とは分けた観測経路で確認する設計です。

この事案から直接検証できるのは公開情報の範囲です。以下はMGLの提案を調べるための模擬試験で、報道された環境の再現やAmazonでの導入評価とは区別します。

試験計画と判定

隔離した環境で、同じ実行主体と書き込み手段を使い、委任範囲に入る合成設定ファイルと、範囲外の保護ファイルへの更新を試します。操作IDごとに、認可判断と対象の試行前後の状態を照合します。

試行	観測する結果
許可範囲内	認可が許可となり、対象の内容が期待値に変わる
許可範囲外	認可が拒否となり、対象の試行前後の内容が一致する
観測の欠落または不一致	結果を確認不能または不一致として記録し、成功扱いを避ける

前提は、操作主体が実行制御点や観測経路の設定を書き換えられず、試験対象の操作が制御点を通ることです。試行前後の比較で確認できるのは、観測した二時点の状態です。一時的な変更と復元を調べるには、追加の観測が必要です。今回の記事は設計と試験計画を示します。

この事案と関連する研究の目的と判定条件は、研究テーマのページにまとめています。 AIエージェントの実行権限と証跡の検証

第002論文・権限要件 · 第003論文・実行制御と証跡 · 技術提言 · 事案一覧

版を固定したWeb記録